TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO

MÔN HỌC

TRIỂN KHAI VÀ QUẢN TRỊ HỆ THỐNG PHẦN MỀM

ĐỀ TÀI

HỆ THỐNG THƯ VIỆN ẢNH

(GALLERY)

Giảng viên hướng dẫn .....
Sinh viên thực hiện Nguyễn Mạnh Cường
Mã sinh viên DTC245200308
Lớp CNTT K23K

Năm 2026

MỤC LỤC

Ghi chú: mục lục được tạo tự động từ tiêu đề chương/mục bằng Microsoft Word; số trang tương ứng với bản in hiện tại. Số liệu hạ tầng và test hồi quy được đo thực tế trên hệ thống đang chạy ngày 23-10-2026; số liệu Playwright là từ đợt kiểm thử giao diện trước.

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI 3
1.1. Giới thiệu 3
1.2. Mục tiêu 3
1.3. Phạm vi 3
1.4. Kết quả chính 3
CHƯƠNG 2. KIẾN TRÚC HỆ THỐNG VÀ LUỒNG REQUEST 5
2.1. Thành phần hệ thống 5
2.2. Luồng xử lý request 5
2.3. Cổng và phạm vi truy cập 5
CHƯƠNG 3. CÔNG NGHỆ VÀ CẤU HÌNH TRIỂN KHAI 7
3.1. Công nghệ sử dụng 7
3.2. Đặc điểm cấu hình Docker Compose 7
3.3. Quy trình triển khai 7
CHƯƠNG 4. CƠ SỞ DỮ LIỆU VÀ CHỨC NĂNG ỨNG DỤNG 8
4.1. Lược đồ dữ liệu 8
4.2. Chức năng chính 8
4.3. Sửa lỗi quyền riêng tư ảnh (L4) 8
CHƯƠNG 5. NGINX, HTTPS VÀ SECURITY HEADERS 11
5.1. Reverse proxy và HTTPS 11
5.2. Security headers thực tế 11
5.3. Giới hạn truy cập 11
CHƯƠNG 6. PROMETHEUS, EXPORTERS VÀ GRAFANA 12
6.1. Kiến trúc giám sát 12
6.2. Trạng thái target (đo ngày 23-10-2026) 12
6.3. Dashboard 12
CHƯƠNG 7. LOKI, PROMTAIL VÀ TRUY VẤN LOGQL 15
7.1. Pipeline thu thập log 15
7.2. Khắc phục lỗi log cũ 15
7.3. Truy vấn LogQL và số dòng thực tế 15
CHƯƠNG 8. HARDENING, PHÂN QUYỀN VÀ BẢO MẬT 17
8.1. Hardening container 17
8.2. Xác thực và phân quyền 17
8.3. Các lỗi đã sửa trong đợt hoàn thiện 17
8.4. Ngoại lệ và tồn đọng 18
CHƯƠNG 9. KIỂM THỬ VÀ KẾT QUẢ 19
9.1. Phương pháp 19
9.2. Test hồi quy 19
9.3. Kịch bản giao diện 19
9.4. Kiểm tra hạ tầng 20
CHƯƠNG 10. ĐÁNH GIÁ, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN 24
10.1. Tự đánh giá theo tiêu chí 24
10.2. Hạn chế 24
10.3. Hướng phát triển 24
10.4. Kết luận 25
Tài liệu tham khảo 25

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Giới thiệu

Hệ thống Thư viện Ảnh (Gallery) là ứng dụng web cho phép người dùng tạo album, tải ảnh, gắn thẻ, tìm kiếm và chia sẻ ảnh cho khách thông qua liên kết có thời hạn. Dự án được triển khai theo mô hình nhiều tầng trên Docker Compose: Nginx làm reverse proxy và kết thúc TLS, ứng dụng Node.js/Express/EJS xử lý nghiệp vụ, MySQL lưu dữ liệu, phpMyAdmin hỗ trợ quản trị cơ sở dữ liệu, Prometheus/Grafana giám sát và Loki/Promtail thu thập log tập trung.

Báo cáo trình bày kết quả kiểm tra, hoàn thiện và vận hành hệ thống: kiến trúc, cấu hình triển khai, bảo mật, giám sát, ghi log và kiểm thử. Mọi số liệu trong báo cáo đều lấy từ lần chạy thực tế, không sử dụng số liệu giả định.

1.2. Mục tiêu

1. Đóng gói toàn bộ ứng dụng và hạ tầng bằng Docker Compose, tái lập được trên máy khác.
2. Triển khai Nginx reverse proxy với HTTPS, security headers và giới hạn tần suất truy cập.
3. Giám sát tài nguyên container, máy chủ, MySQL, Nginx và ứng dụng bằng Prometheus + Grafana.
4. Thu thập và truy vấn log tập trung bằng Loki + Promtail với LogQL.
5. Áp dụng hardening hợp lý nhưng không làm hỏng chức năng hiện có.
6. Kiểm thử thực tế các luồng chính và các lỗi bảo mật đã phát hiện.
7. Hoàn thiện tài liệu: README, hướng dẫn vận hành, changelog và báo cáo.

1.3. Phạm vi

Phạm vi gồm 12 service trong một Docker Compose: web, db, phpmyadmin, nginx, prometheus, grafana, loki, promtail, cadvisor, node-exporter, mysqld-exporter, nginx-prometheus-exporter. Hệ thống chạy trên một máy (single host), phục vụ mục đích học tập và demo, không cam kết tính sẵn sàng cao hay chứng chỉ TLS công khai.

1.4. Kết quả chính

- 12/12 container ở trạng thái healthy; ứng dụng truy cập qua https://localhost.

- 6/6 Prometheus target UP, `mysql_up=1`; Grafana có 2 datasource OK và 5 dashboard.
- Loki nhận log thật từ container và file ứng dụng; đã khắc phục lỗi `entry too far behind` khi Promtail khởi động lại.
- Sửa lỗi rò rỉ ảnh thuộc album riêng tư trên trang tổng hợp thẻ (L4) và bổ sung test hồi quy.
- Chuẩn hóa đăng xuất bằng POST + CSRF, thông báo đăng nhập trung tính, ẩn lỗi nội bộ khỏi `/health`.
- Bộ test hồi quy 8/8 PASS (chạy lại ngày 23-10-2026); kịch bản kiểm thử giao diện đạt 32/32 bước trong đợt kiểm thử trước.

CHƯƠNG 2. KIẾN TRÚC HỆ THỐNG VÀ LUỒNG REQUEST

2.1. Thành phần hệ thống

Thành phần	Vai trò	Mạng nội bộ
nginx	Reverse proxy, TLS, security headers, rate limit	frontend
web	Node.js 20 + Express + EJS, API và giao diện	frontend, backend, monitoring
db	MySQL 8.0, dữ liệu người dùng/album/ảnh/tag/chia sẻ	backend
phpmyadmin	Giao diện quản trị MySQL (loopback)	frontend, backend
prometheus	Thu thập metrics, đánh giá target	monitoring
grafana	Dashboard, datasource Prometheus + Loki	monitoring
loki	Kho log tập trung	monitoring
promtail	Đọc log Docker và file, đẩy về Loki	monitoring, host-access
cadvisor	Metrics container	monitoring, host-access
node-exporter	Metrics máy chủ	monitoring, host-access
mysqld-exporter	Metrics MySQL	monitoring, backend
nginx-prometheus-exporter	Metrics Nginx	monitoring, frontend

2.2. Luồng xử lý request

1. Trình duyệt gửi request tới `https://localhost` (cổng 443 của host).
2. Nginx kiểm tra rate limit, thêm security headers, chuyển tiếp tới `web:3000` qua mạng `frontend`.
3. Express xác thực phiên (cookie `gallery.sid` ký bằng `SESSION_SECRET`, lưu trong MySQL), kiểm tra CSRF với mọi POST, rồi gọi controller.
4. Controller truy vấn MySQL qua pool `mysql2`; ảnh/thumbnail lưu trong `app/public/uploads` (mount từ host).
5. EJS render HTML trả về Nginx, Nginx trả cho trình duyệt.
6. Song song, Prometheus scrape metrics của web/exporters; Promtail đọc log container và file log ứng dụng rồi đẩy vào Loki; Grafana truy vấn cả hai nguồn.

2.3. Cổng và phạm vi truy cập

Dịch vụ	Ánh xạ cổng	Phạm vi

Dịch vụ	**Ánh xạ cổng**	**Phạm vi**
nginx	0.0.0.0:80 → 8080, 0.0.0.0:443 → 8443	Toàn bộ host
grafana	127.0.0.1:3000 → 3000	Chỉ loopback
phpmyadmin	127.0.0.1:8080 → 80	Chỉ loopback
prometheus	127.0.0.1:9090 → 9090	Chỉ loopback
loki	127.0.0.1:3100 → 3100	Chỉ loopback
node-exporter / cadvisor / mysqld-exporter / nginx-exporter	127.0.0.1:9100 / 8081 / 9104 / 9113	Chỉ loopback
db	Không publish	Chỉ mạng backend

Việc chỉ publish cổng 80/443 ra ngoài và bind các cổng còn lại vào loopback giúp giảm bề mặt tấn công khi máy chạy trong mạng LAN.

CHƯƠNG 3. CÔNG NGHỆ VÀ CẤU HÌNH TRIỂN KHAI

3.1. Công nghệ sử dụng

Thành phần	Phiên bản	Ghi chú
Node.js / Express / EJS	20.20.2-alpine / 4.18 / 3.1	Ứng dụng web, render phía server
MySQL / phpMyAdmin	8.0.46 / 5.2.3	Cơ sở dữ liệu và giao diện quản trị
Nginx unprivileged	1.31.6-alpine	Reverse proxy, TLS, headers
Prometheus / Grafana	3.15.0 / 13.2.3	Giám sát và dashboard
Loki / Promtail	3.7.8 / 3.6.8	Logging tập trung
cAdvisor / node-exporter / mysqld-exporter / nginx-exporter	0.55.1 / 1.12.1 / 0.20.0 / 1.4.2	Các exporter
Docker Compose	v2	Điều phối 12 service

3.2. Đặc điểm cấu hình Docker Compose

- Mỗi service có healthcheck riêng; web chỉ khởi động khi db healthy và nginx chỉ nhận traffic khi web healthy.
- Giới hạn tài nguyên bằng `mem_limit` và `cpus` cho từng service.
- Log Docker xoay vòng `max-size: 10m`, `max-file: 3` cho cả 12 service (neo YAML dùng chung).
- Các service không cần quyền ghi dùng `read_only: true` + `tmpfs`; drop toàn bộ capability; bật `no-new-privileges`.
- Ba mạng nội bộ tách biệt: `frontend`, `backend`, `monitoring`; Promtail dùng thêm `host-access` để đọc Docker socket.
- Health probe tĩnh trong image `healthcheck` dùng cho các image distroless không có shell/curl (Loki, Promtail, Nginx exporter).

3.3. Quy trình triển khai

1. `cp .env.example .env` và điền các biến bắt buộc.
2. `docker compose config --quiet` để kiểm tra cú pháp.
3. `docker compose up -d --build` để build image và khởi chạy.
4. `docker compose ps` xác nhận 12/12 healthy.
5. Chạy seed dữ liệu demo và kiểm tra các URL dịch vụ.

CHƯƠNG 4. CƠ SỞ DỮ LIỆU VÀ CHỨC NĂNG ỨNG DỤNG

4.1. Lược đồ dữ liệu

Bảng	Vai trò	Số dòng hiện tại
users	Tài khoản, vai trò (admin/user), trạng thái khóa	3
albums	Album ảnh, cờ công khai/riêng tư, chủ sở hữu	5
photos	Ảnh, đường dẫn file, thumbnail, album, cờ công khai	25
tags	Danh mục thẻ	32
photo_tags	Liên kết nhiều-nhiều giữa ảnh và thẻ	82
share_links	Token chia sẻ, thời hạn, trạng thái thu hồi	1
sessions	Phiên đăng nhập (thay cho MemoryStore)	130 (tại thời điểm 23-10-2026)

Khóa ngoại dùng `ON DELETE CASCADE` cho album/ảnh/tag, nhờ đó khi xóa album thì ảnh và liên kết tag tương ứng được dọn theo. Mật khẩu lưu dưới dạng hash bcrypt, không lưu plaintext.

4.2. Chức năng chính

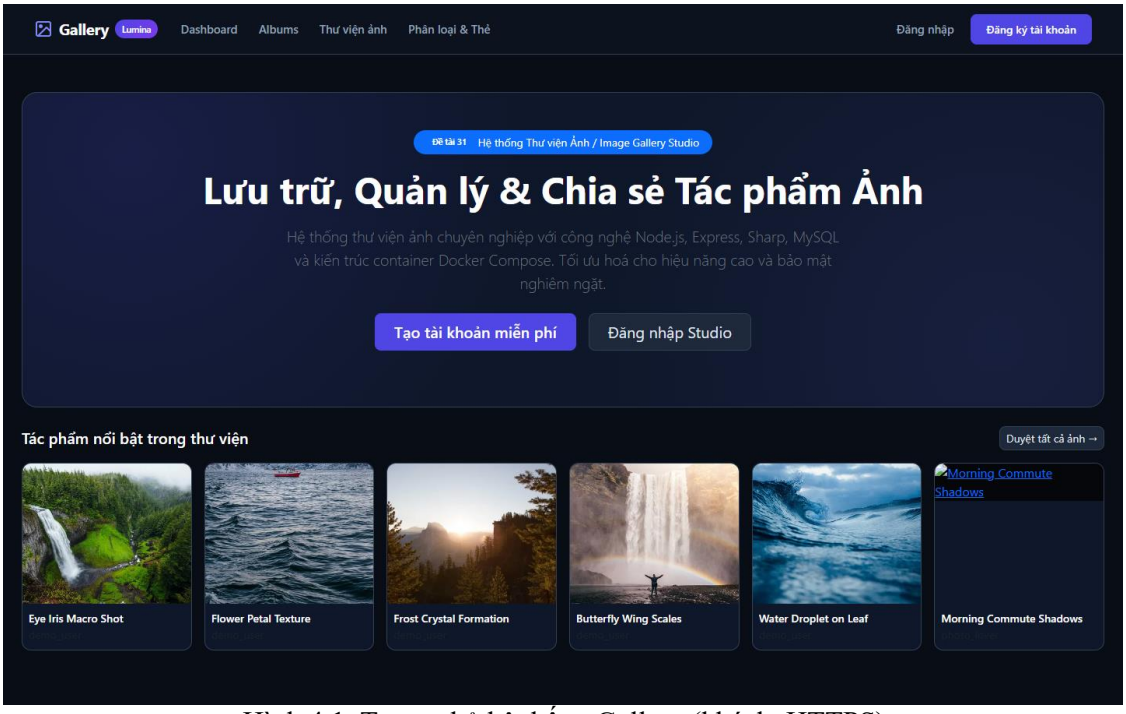
- **Đăng ký/đăng nhập:** kiểm tra định dạng username, email, độ mạnh mật khẩu; phiên lưu trong MySQL với cookie HttpOnly, SameSite=Strict.
- **Quản lý album:** tạo, sửa, xóa; đánh dấu công khai hoặc riêng tư.
- **Upload ảnh:** nhiều ảnh mỗi lần, tạo thumbnail WebP bằng Sharp, giới hạn 10 MB/ảnh.
- **Gắn thẻ và tìm kiếm:** tag chuẩn hóa, tìm theo tên ảnh/album/tag, phân trang giữ bộ lọc.
- **Chia sẻ:** link token có thời hạn 1/7/30 ngày, thu hồi tức thời.
- **Quản trị:** danh sách người dùng, khóa/mở tài khoản, xóa nội dung vi phạm.

4.3. Sửa lỗi quyền riêng tư ảnh (L4)

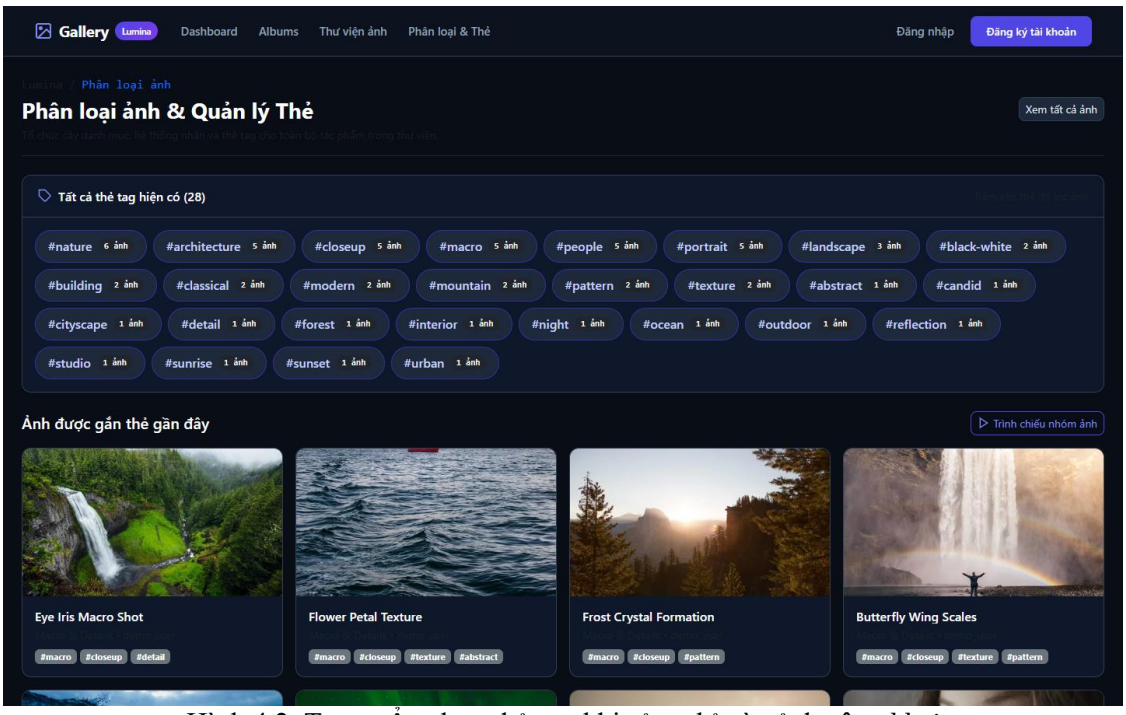
Trước khi sửa, trang `/photos/tags` chỉ kiểm tra `photos.is_public` mà bỏ qua trạng thái của album. Hệ quả: khách không đăng nhập vẫn thấy tiêu đề và thumbnail của 5 ảnh (id 66-70) thuộc album 14 đang ở chế độ riêng tư; các thumbnail này trả 404 khi mở, tạo trải nghiệm lỗi và rò rỉ thông tin.

Sau khi sửa, điều kiện hiển thị là: ảnh công khai **và** album chứa ảnh công khai, hoặc người xem là chủ sở hữu, hoặc người xem là admin. Số lượng ảnh của mỗi tag được đếm bằng `COUNT(p.id)` sau khi join, nên tag chỉ gắn với ảnh riêng tư không còn xuất hiện với khách.

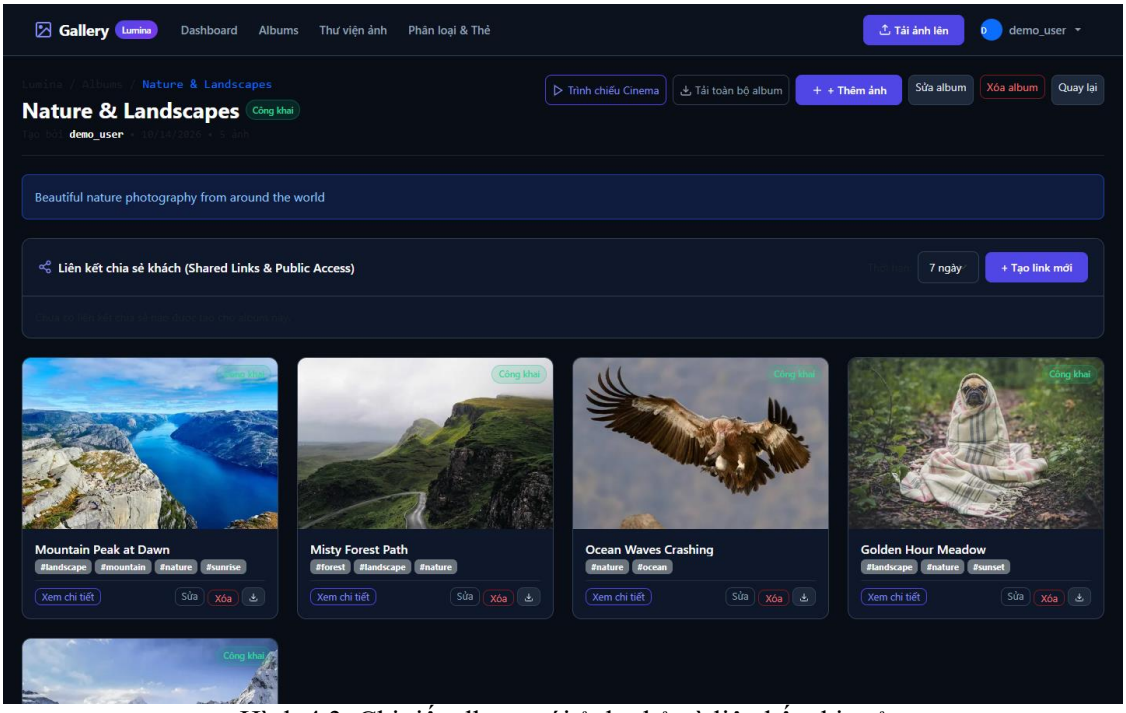
Kiểm tra	**Trước khi sửa**	**Sau khi sửa**
Ảnh 66-70 trên /photos/tags (khách)	Có trong HTML	Không còn
Thumbnail lỗi 404 trên trang tags	5 ảnh hỏng	0 ảnh hỏng (12/12 ảnh trả 200)
Tag chỉ gắn với ảnh riêng tư	Vẫn hiển thị	Bị loại khỏi danh sách
Ảnh công khai vẫn hiển thị	Có	Có (12 ảnh)



Hình 4.1. Trang chủ hệ thống Gallery (khách, HTTPS)



Hình 4.2. Trang tổng hợp thẻ sau khi sửa: chỉ còn ảnh công khai



Hình 4.3. Chi tiết album với ảnh, thẻ và liên kết chia sẻ

CHƯƠNG 5. NGINX, HTTPS VÀ SECURITY HEADERS

5.1. Reverse proxy và HTTPS

Nginx dùng image `nginx-unprivileged`, lắng nghe 8080/8443 trong container và được publish ra 80/443 trên host. Request HTTP được chuyển hướng 301 sang HTTPS. Chứng chỉ tự ký được tạo trong volume `nginx_certs` để không đưa khóa vào Git.

5.2. Security headers thực tế

Header	Giá trị đang trả về
Content-Security-Policy	default-src 'self'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'; object-src 'none'; img-src 'self' data: https:; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'
Strict-Transport-Security	max-age=31536000; includeSubDomains
X-Frame-Options	DENY
X-Content-Type-Options	nosniff
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	camera=(), microphone=(), geolocation=(), payment=(), usb=()
X-Powered-By	Không còn (đã ẩn ở cả Express và Nginx)

5.3. Giới hạn truy cập

- `limit_req_zone` cho API 10 request/giây, cho `/login` và `/register` 5 request/phút với burst 5; vượt ngưỡng trả 429.
- `location = /metrics` trả 403 với mọi request từ bên ngoài; Prometheus scrape trực tiếp `web:3000/metrics` trong mạng nội bộ.
- Giới hạn kích thước body và thời gian đọc để chống lạm dụng tài nguyên.

CHƯƠNG 6. PROMETHEUS, EXPORTERS VÀ GRAFANA

6.1. Kiến trúc giám sát

Prometheus scrape 6 job: chính nó, ứng dụng web, cAdvisor, node-exporter, mysqld-exporter và nginx-prometheus-exporter. Dữ liệu được lưu trong volume `prometheus_data`. Grafana được provision datasource Prometheus/Loki với UID cố định và 5 dashboard JSON đặt trong `grafana/provisioning`.

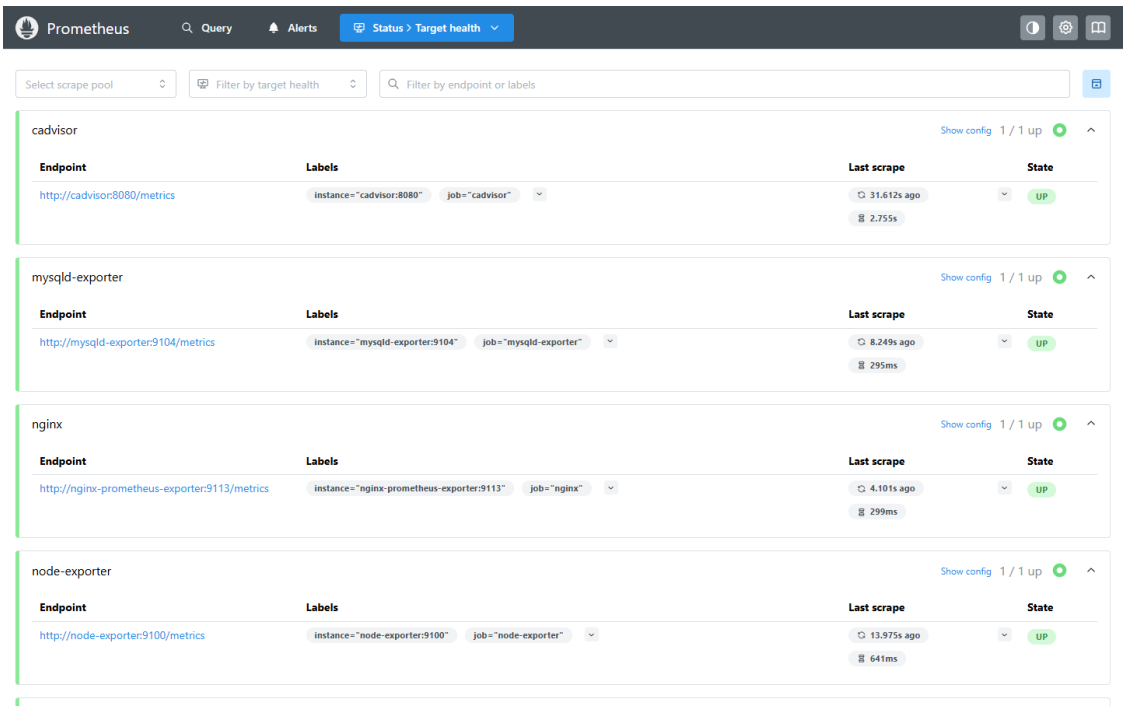
6.2. Trạng thái target (đo ngày 23-10-2026)

Job	Mục tiêu	Trạng thái
prometheus	prometheus:9090	UP
web	web:3000/metrics	UP
cadvisor	cadvisor:8080	UP
node-exporter	node-exporter:9100	UP
mysqld-exporter	mysqld-exporter:9104	UP
nginx-prometheus-exporter	nginx-prometheus-exporter:9113	UP

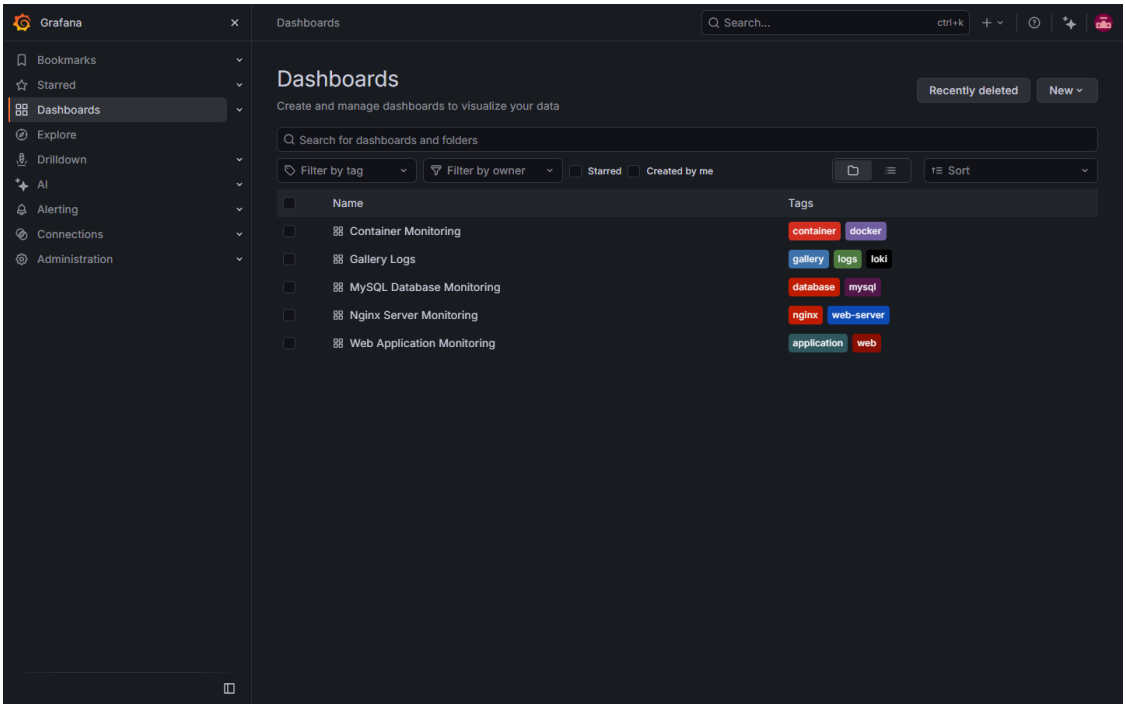
Truy vấn kiểm chứng: `mysql_up` trả giá trị 1; tổng số target active là 6, không có target down.

6.3. Dashboard

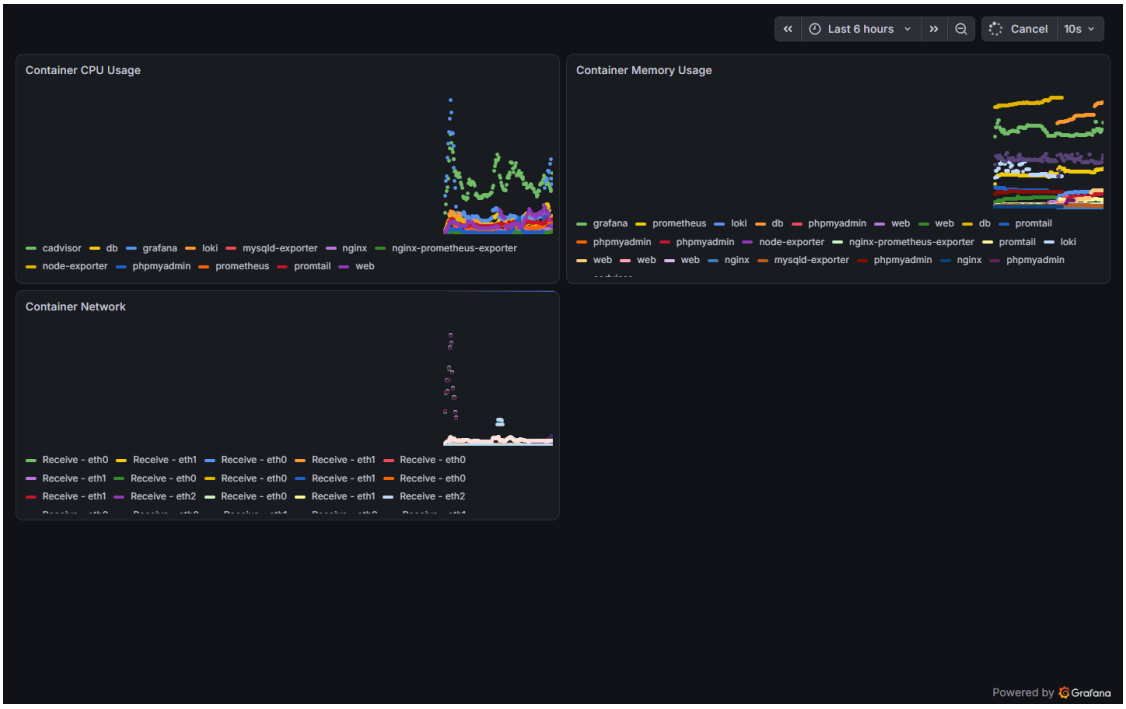
- **Container Monitoring:** CPU, RAM, network theo từng container.
- **MySQL Database Monitoring:** trạng thái, kết nối, truy vấn/giây.
- **Nginx Server Monitoring:** kết nối, request/giây.
- **Web Application Monitoring:** metrics ứng dụng (prom-client).
- **Gallery Logs:** log container/Nginx và lọc 4xx/5xx.



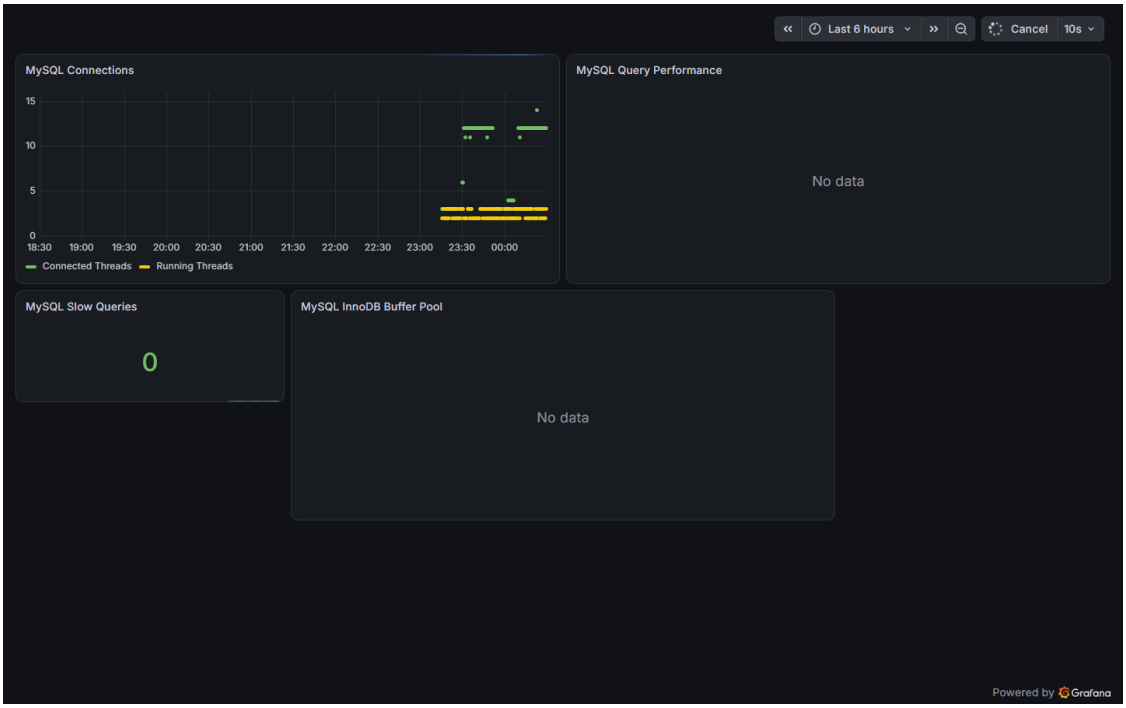
Hình 6.1. Prometheus: 6/6 target UP



Hình 6.2. Grafana: 5 dashboard được provision tự động



Hình 6.3. Dashboard Container Monitoring



Hình 6.4. Dashboard MySQL Database Monitoring

CHƯƠNG 7. LOKI, PROMTAIL VÀ TRUY VẤN LOGQL

7.1. Pipeline thu thập log

Promtail chạy với quyền đọc Docker socket, tự phát hiện container thuộc project gallery, gắn nhãn container, service, stream và đẩy log JSON về Loki. Ngoài ra Promtail đọc file app/src/logs/*.log của ứng dụng (job application) và parse JSON để lọc theo level, route, status_code.

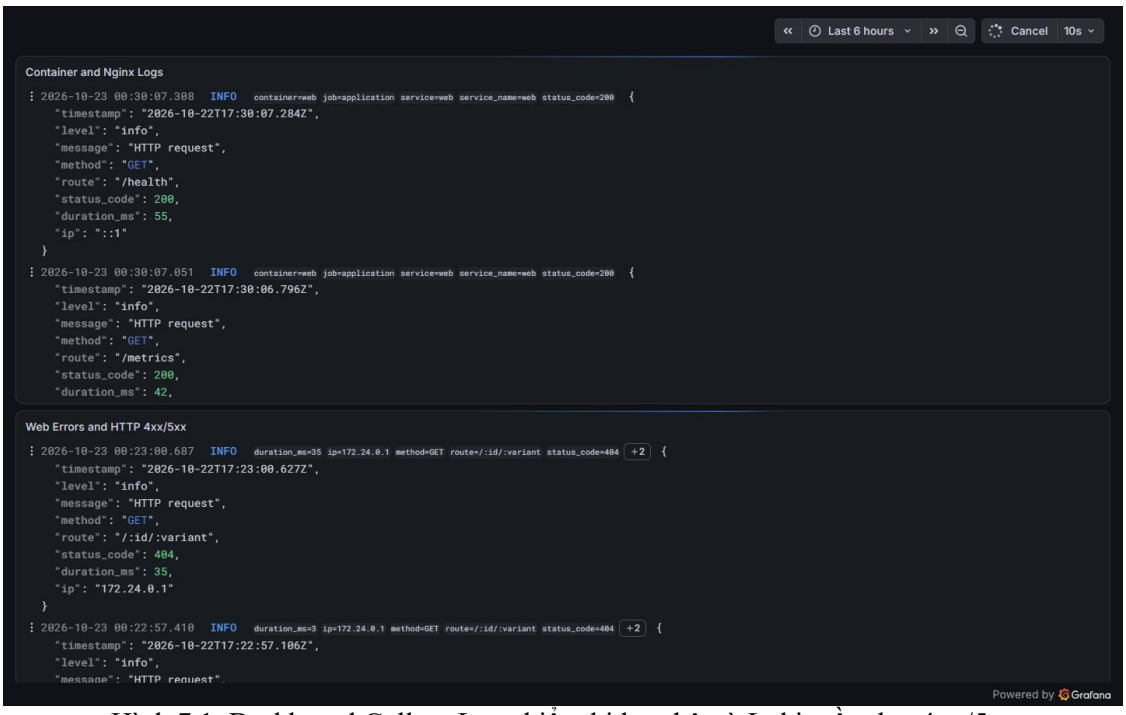
7.2. Khắc phục lỗi log cũ

Trước khi sửa, mỗi lần Promtail khởi động lại, file positions nằm trong /tmp bị mất nên Promtail đọc lại toàn bộ log cũ. Loki từ chối các bản ghi cũ hơn đầu stream với thông báo entry too far behind và ghi log lỗi liên tục. Đã xử lý bằng hai biện pháp: lưu positions vào volume promtail_data và bỏ các log container cũ hơn 24 giờ trước khi gửi. Sau khi sửa, log Promtail không còn bản ghi final error.

7.3. Truy vấn LogQL và số dòng thực tế

Mục đích	Truy vấn	Số dòng (24h)
Tổng log mọi container	sum(count_over_time({container=~".+"}[24h]))	20.003
Log HTTP của ứng dụng	sum(count_over_time({container="web"} |= "HTTP request" [24h]))	10.834
Log Nginx	sum(count_over_time({container="nginx"}[24h]))	1.664
Lỗi mức error	sum(count_over_time({job="application"} | json | level="error" [24h])) or vector(0)	0
HTTP 5xx của ứng dụng	sum(count_over_time({container="web"} | json | status_code >= 500 [24h])) or vector(0)	3
Dò request đăng nhập	sum(count_over_time({container="web"} |= "login" [24h]))	203

Số liệu đo lúc 01:20 ngày 23-10-2026 (giờ Việt Nam); các giá trị tăng dần vì log được ghi liên tục. Ba dòng 5xx là GET /health trả 503 trong lúc container db được tạo lại (16:57 ngày 22-10 và 03:01 ngày 15-10), không phải lỗi nghiệp vụ. Đây cũng là bằng chứng healthcheck phản ánh đúng trạng thái phụ thuộc.



Hình 7.1. Dashboard Gallery Logs hiển thị log thật từ Loki, gồm lọc 4xx/5xx

CHƯƠNG 8. HARDENING, PHÂN QUYỀN VÀ BẢO MẬT

8.1. Hardening container

Biện pháp	Áp dụng	Ghi chú
read_only + tmpfs	web, nginx, loki, prometheus, promtail, exporter	Không ghi vào rootfs
cap_drop: ALL	web, nginx, loki, prometheus, promtail, cadvisor	phpMyAdmin/Grafana là ngoại lệ có lý do
no-new-privileges	Toàn bộ 12 service	Chặn leo thang đặc quyền
user không phải root	web, nginx (unprivileged image)	Giảm tác động nếu bị khai thác
Log rotation	Toàn bộ service	10 MB × 3 file
Cổng chỉ loopback	Grafana, Prometheus, phpMyAdmin, Loki, exporters	Chỉ Nginx public 80/443

8.2. Xác thực và phân quyền

- Mật khẩu hash bcrypt; không trả về hash trong bất kỳ view nào.
- Phiên lưu MySQL, cookie ký HMAC bằng `SESSION_SECRET` (bắt buộc ≥ 32 ký tự ở production).
- Mọi POST đều kiểm tra CSRF; thiếu token trả 403.
- Route admin kiểm tra `req.user.role === 'admin'`; người dùng thường nhận trang 403 thay vì 404 gây nhầm lẫn.
- Kiểm soát quyền xem ảnh/album ở cả trang chi tiết, media và thumbnail; khách nhận 404 với tài nguyên riêng tư.

8.3. Các lỗi đã sửa trong đợt hoàn thiện

Mã	Nội dung	Cách xử lý	Kiểm chứng
L4	Lộ ảnh album riêng tư trên /photos/tags	Lọc theo cả album, đếm tag theo ảnh hiển thị	5 test + kiểm tra HTML
L8	Thiếu header, lộ X-Powered-By	Bổ sung CSP/HSTS/Permissions-Policy, ẩn header	curl -D -
L10	Log Docker không giới hạn	json-file 10m × 3	docker inspect
L11	Đăng xuất bằng GET, xóa sai cookie	POST + CSRF + clearCookie gallery.sid	Test 403/302, E2E
L12	Thông báo đăng nhập lộ tài khoản	Một thông báo trung tính, validate email/username	Đăng nhập sai

Mã	Nội dung	Cách xử lý	Kiểm chứng
L15	Loki báo entry too far behind	Volume positions + bỏ log cũ 24h	Log promtail sạch
L16	/health lộ lỗi, admin trả 404	Ẩn chi tiết lỗi, trang 403	curl /health, E2E

8.4. Ngoại lệ và tồn đọng

- **phpMyAdmin:** image cần quyền root để chown cấu hình và Apache cần setuid/setgid; đã kiểm tra và ghi nhận ngoại lệ thay vì ép cấu hình làm service hỏng.
- **Grafana:** cần filesystem ghi được cho plugin updater; vẫn giữ cap_drop và no-new-privileges.
- **CSP:** còn `'unsafe-inline'` do template dùng inline script và thuộc tính `onclick`.
- **Quyền DB runtime:** `app_user` hiện chỉ có SELECT, INSERT, UPDATE, DELETE trên `gallery_db`; gallery_exporter có SELECT, PROCESS, REPLICATION CLIENT trên *.* cho monitoring; startup chỉ probe đọc.
- **Mật khẩu:** chưa đổi mật khẩu MySQL/Grafana sang chuỗi mạnh hơn; việc này cũng cần phê duyệt để tránh gián đoạn demo.

CHƯƠNG 9. KIỂM THỬ VÀ KẾT QUẢ

9.1. Phương pháp

Kiểm thử gồm ba lớp: (1) kiểm tra cấu hình và hạ tầng bằng Docker/curl; (2) test hồi quy chạy trong container, chỉ đọc DB và gọi HTTP; (3) kịch bản Playwright trên giao diện thật với dữ liệu kiểm thử cô lập, dọn sạch sau khi chạy. Các luồng có tạo dữ liệu chỉ chạy với user/album kiểm thử riêng.

9.2. Test hồi quy

Ca kiểm thử	Kết quả
Khách không thấy ảnh thuộc album riêng tư trên /photos/tags	PASS
Khách không thấy ảnh thuộc album riêng tư trên trang chủ	PASS
Album/ảnh/thumbnail riêng tư trả 404 cho khách	PASS
Ảnh công khai vẫn xem được (chi tiết + thumbnail 200)	PASS
Link chia sẻ hợp lệ phục vụ ảnh; token sai trả 404	PASS
Route không tồn tại trả 404, không lộ stack trace	PASS
/health không chứa trường error	PASS
GET /logout không hủy phiên; POST thiếu CSRF trả 403	PASS

Tổng: 8/8 PASS khi chạy lại docker compose exec -T web node --test test/ ngày 23-10-2026.

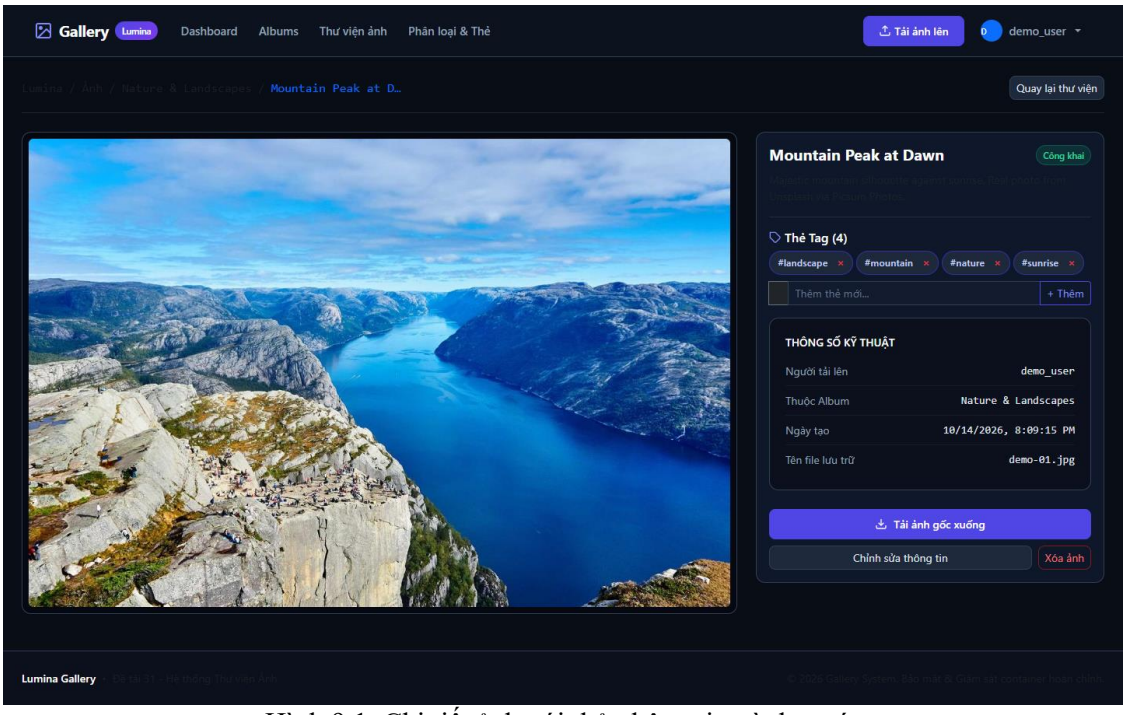
9.3. Kịch bản giao diện

Nhóm chức năng	Các bước đã chạy	Kết quả
Khách	Trang chủ, album, tag, đăng nhập, đăng ký	PASS
Người dùng	Đăng nhập, xem album/ảnh, tìm kiếm, upload form, /admin bị chặn 403	PASS
Đăng xuất	POST có CSRF, phiên bị xóa	PASS
Admin	Đăng nhập, mở /admin, xem danh sách người dùng	PASS
Đăng ký mới	Tạo tài khoản kiểm thử, đăng nhập	PASS
Album + upload	Tạo album riêng tư, upload ảnh, xem trong album	PASS
Tag + tìm kiếm	Gắn tag, tìm theo tag	PASS
Chia sẻ	Tạo link, khách mở link, thu hồi link trả 404	PASS
IDOR	Khách mở album/ảnh/thumbnail riêng tư đều 404	PASS

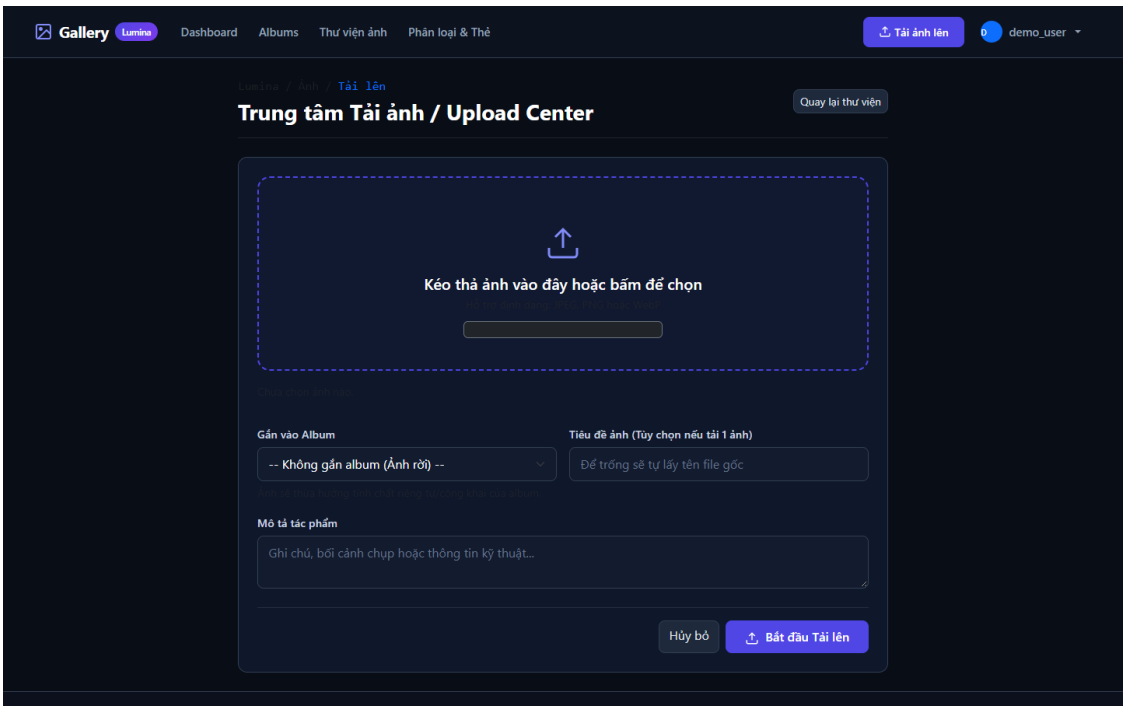
Tổng: 32/32 bước PASS trong đợt kiểm thử giao diện trước; chưa chạy lại trong phiên 23-10-2026. Dữ liệu kiểm thử (user e2e_*, album, ảnh, file upload) đã được xóa; DB trở về 3 user / 5 album / 25 ảnh / 73 file.

9.4. Kiểm tra hạ tầng

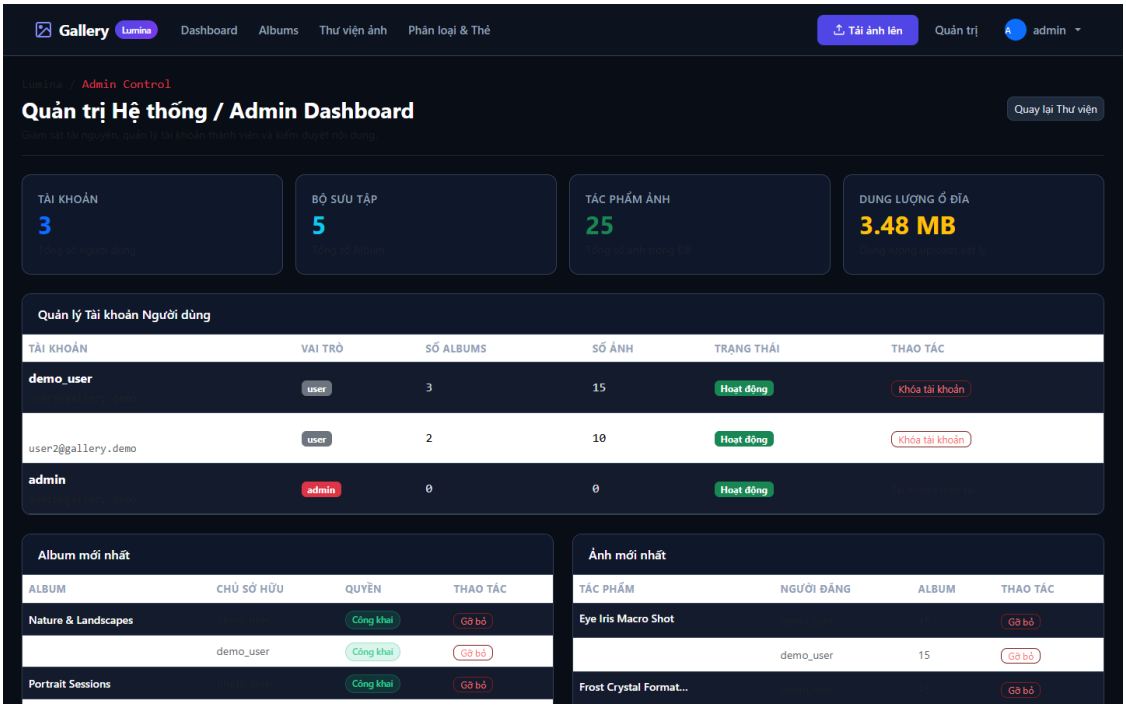
Hạng mục	Kết quả thực tế
docker compose config --quiet	exit 0
docker compose ps	12/12 healthy
HTTP → HTTPS	301 tới https://localhost/
/metrics qua Nginx	403
Rate limit /login	429 khi vượt 5 request/phút
Prometheus targets	6/6 UP
mysql_up	1
Grafana datasource	Prometheus OK, Loki OK
Loki query	Trả dữ liệu thật (bảng 7.3)
phpMyAdmin	Đăng nhập và xem cấu trúc gallery_db



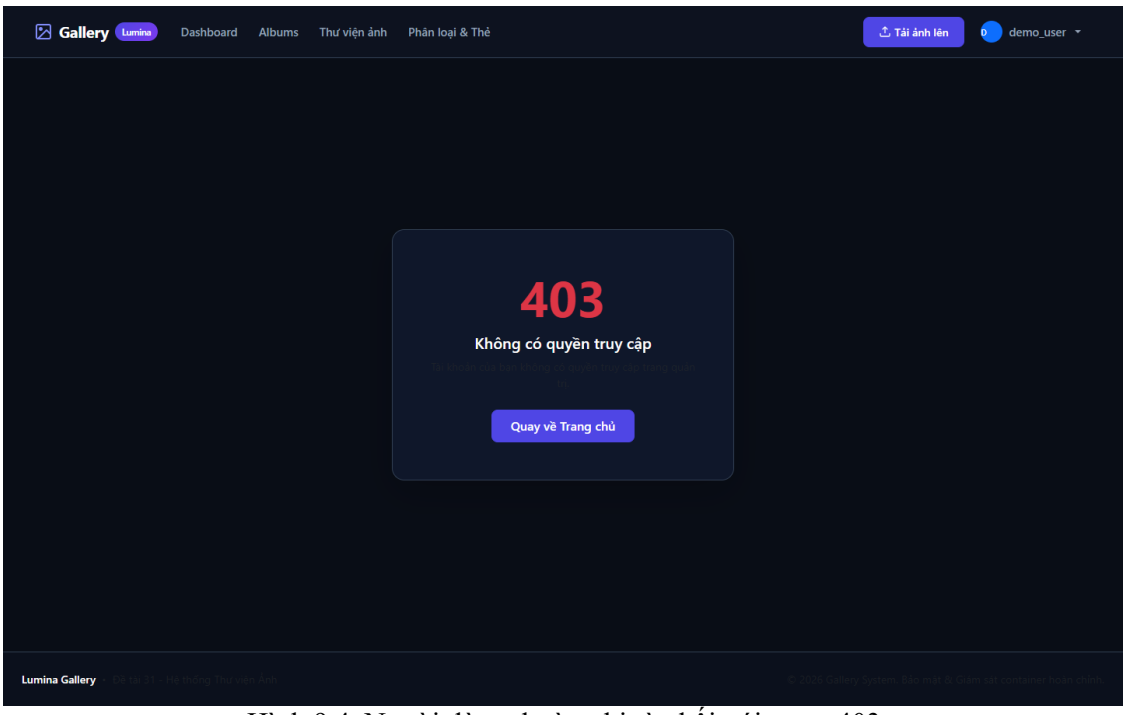
Hình 9.1. Chi tiết ảnh với thẻ, thông tin và thao tác



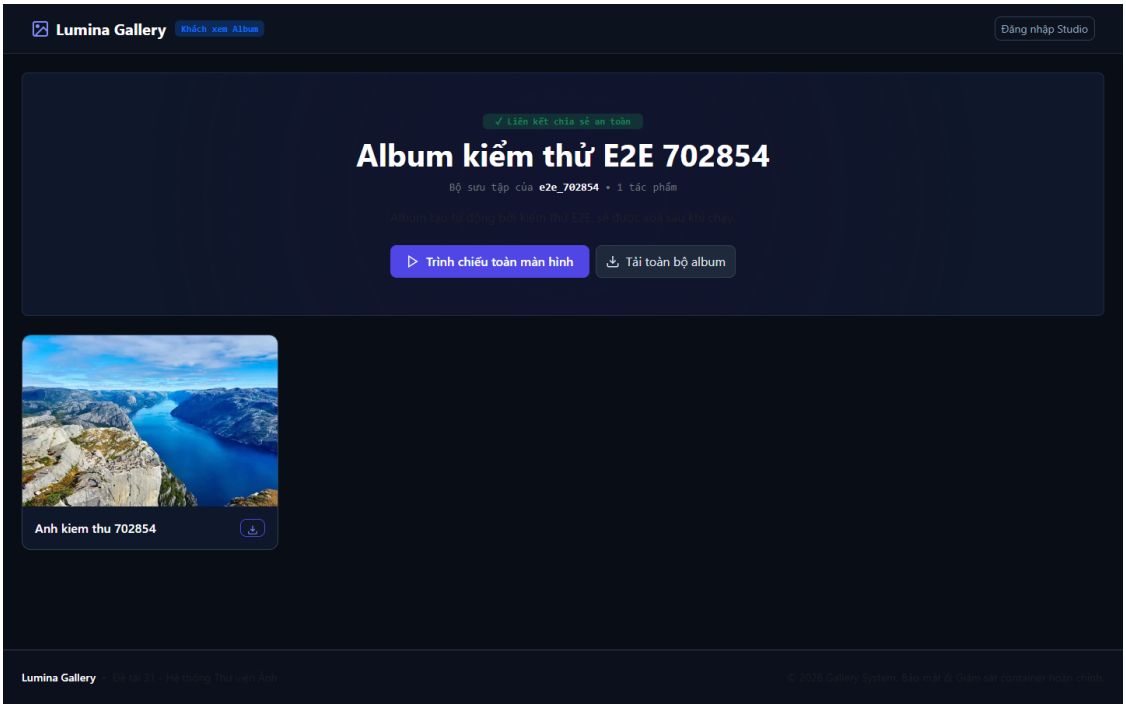
Hình 9.2. Trang upload ảnh



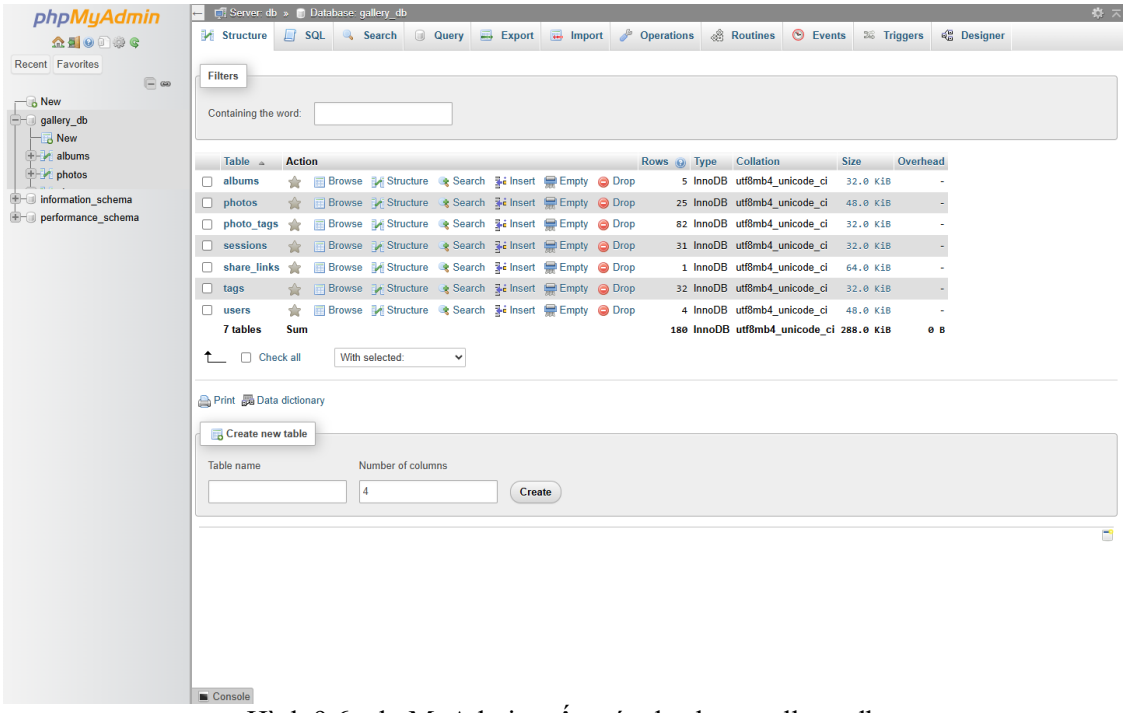
Hình 9.3. Trang quản trị dành cho admin



Hình 9.4. Người dùng thường bị từ chối với trang 403



Hình 9.5. Khách xem album qua link chia sẻ còn hiệu lực



Hình 9.6. phpMyAdmin: cấu trúc database gallery_db

CHƯƠNG 10. ĐÁNH GIÁ, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN

10.1. Tự đánh giá theo tiêu chí

Tiêu chí	Bằng chứng	Mức đạt
1. Đóng gói Docker	12 service, Dockerfile riêng, compose config hợp lệ	Đạt
2. Triển khai và vận hành	12/12 healthy, HTTPS, healthcheck, hướng dẫn vận hành	Đạt
3. Bảo mật	CSRF, session MySQL, headers, rate limit, 403/404 đúng; còn ngoại lệ đã ghi rõ	Đạt (còn tồn đọng)
4. Giám sát	6/6 target, 5 dashboard, mysql_up=1	Đạt
5. Ghi log tập trung	Loki + Promtail, LogQL thật, dashboard Gallery Logs	Đạt
6. Quản lý mã nguồn	Git nhánh dev/main, changelog, README, tài liệu	Đạt
7. Báo cáo và minh chứng	Báo cáo 10 chương, 24 ảnh chụp thực tế, số liệu đo được	Đạt

10.2. Hạn chế

- Chứng chỉ TLS tự ký, chỉ phù hợp môi trường học tập.
- CSP còn `'unsafe-inline'` do inline script/onclick trong EJS.
- `app_user` đã được thu hẹp còn DML; mật khẩu MySQL/Grafana chưa đổi sang chuỗi mạnh hơn (cần phê duyệt).
- phpMyAdmin và Grafana không thể áp dụng read-only/drop toàn bộ capability.
- Chưa có Alertmanager và chưa bật compactor retention cho Loki.
- Hệ thống chạy single-host, chưa có cơ chế HA.

10.3. Hướng phát triển

- Thay self-signed bằng CA nội bộ hoặc Let's Encrypt (khi có tên miền).
- Dùng nonce cho CSP, bỏ dần inline script/onclick.
- Duy trì quyền runtime DML-only; tách tài khoản migrate và runtime; rà soát quyền định kỳ.
- Bổ sung Alertmanager, retention cho Loki, backup định kỳ và kiểm thử khôi phục.
- Thêm pipeline CI (lint, test, build image) trước khi phát hành.

10.4. Kết luận

Hệ thống Gallery đã đáp ứng đầy đủ yêu cầu của đề tài 31: đóng gói bằng Docker Compose, reverse proxy HTTPS với security headers, giám sát bằng Prometheus/Grafana, ghi log tập trung bằng Loki/Promtail, phân quyền và kiểm soát quyền riêng tư ảnh. Các lỗi nghiêm trọng được phát hiện trong quá trình kiểm tra đã được sửa và có test hồi quy. Các tồn đọng còn lại đã được ghi rõ, kèm điều kiện cần phê duyệt trước khi thực hiện.

Tài liệu tham khảo

- Docker Documentation — https://docs.docker.com/
- Nginx Documentation — https://nginx.org/en/docs/
- Prometheus Documentation — https://prometheus.io/docs/
- Grafana Documentation — https://grafana.com/docs/
- Loki Documentation — https://grafana.com/docs/loki/latest/
- MySQL Reference Manual — https://dev.mysql.com/doc/
- OWASP Top 10 — https://owasp.org/www-project-top-ten/